

**DAFFODIL INTERNATIONAL UNIVERSITY**

**Faculty of Science and Information Technology (FSIT)**  
**Department of Computing and Information System (CIS)**

**SEMESTER ASSIGNMENT****Network Security and Cryptographic Solution Design**

**Selected Topic: Protecting Social Media Accounts from Hacking**

|                        |                                                                             |
|------------------------|-----------------------------------------------------------------------------|
| <b>Course Title</b>    | Network Security and Cryptography                                           |
| <b>Course Code</b>     | CIS311                                                                      |
| <b>Level / Term</b>    | Level 2, Term 3                                                             |
| <b>Student Name</b>    | Fayek Ahanaf                                                                |
| <b>Student ID</b>      | 252-16-056                                                                  |
| <b>Section</b>         | 20_A                                                                        |
| <b>Submitted To</b>    | Sifat Jahan Sorna<br>Lecturer Deft of CIS Daffodil International University |
| <b>Submission Date</b> | 3 August 2026                                                               |

## Executive Summary

Social media accounts store private messaging, photos, address books, personal details, and public reputation. Therefore, an account takeover may result in service abuse, impersonation, harassment, privacy violations, and reputational damage to third parties. This paper suggests a secure design for the realistic evaluation platform named Secure Connect. The design is based on authentication, cryptography, Public Key Infrastructure (PKI), secure sessions, monitoring, and controlled recovery. It uses a hybrid approach that does not depend on a single point of failure.

The recommended cryptography suite includes Transport Layer Security (TLS) 1.3 for server authentication and ephemeral traffic encryption, Advanced Encryption Standard (AES)-256-Galois/Counter Mode (GCM) for stored data security, and Rivest-Shamir-Adleman (RSA)-3072 for selected PKI operations. Stolen data cannot be decrypted without physical access to the storage. Passwords are protected by salting and Argon2id hashing. Phishing-resistant passkeys are suggested for high-risk accounts with multi-factor authenticator apps as an alternative. The most critical user data, including approval of recovery sessions and addition of new authenticators, are safeguarded by SHA-256 hashing and digital signing. This way, any unauthorized alteration attempts can be detected.

The evaluation results demonstrate that cryptography can improve confidentiality, integrity, and non-repudiation. However, it is not sufficient to address all security concerns. Malicious software on the endpoint device, social engineering, weak or nonexistent recovery procedures, insider threats, compromised certificates, and denial-of-service attacks require additional attention. The secure design recommends the principle of defense in depth, least privilege, hardware-level encryption, short-lived cryptographic keys, rate-limiting, monitoring, logging, reliable backups, and incident response plan to mitigate these risks.

## Scenario, Scope and Assumptions

SecureConnect is treated as a medium-sized social media service that provides a web application and mobile application. Users can create profiles, publish posts, exchange direct messages and recover an account when an authenticator is lost. The report focuses on the protection of account credentials, authentication traffic, session tokens, profile data, private messages and security-event records. The proposal is a design-level solution rather than a vendor-specific deployment guide.

### Design assumption

The highest-value target is the user account. Therefore, the recovery process, session lifecycle and administrator access are protected at least as strongly as the normal login process. A secure password is useful, but it is not considered sufficient on its own.

## Abbreviations

| Term         | Meaning                                     |
|--------------|---------------------------------------------|
| <b>AES</b>   | Advanced Encryption Standard                |
| <b>CA</b>    | Certificate Authority                       |
| <b>CIA</b>   | Confidentiality, Integrity and Availability |
| <b>CRL</b>   | Certificate Revocation List                 |
| <b>ECDHE</b> | Elliptic-Curve Diffie-Hellman Ephemeral     |
| <b>HSM</b>   | Hardware Security Module                    |
| <b>IPsec</b> | Internet Protocol Security                  |
| <b>MFA</b>   | Multi-Factor Authentication                 |
| <b>OCSP</b>  | Online Certificate Status Protocol          |
| <b>PKI</b>   | Public Key Infrastructure                   |
| <b>RSA</b>   | Rivest-Shamir-Adleman                       |
| <b>SIEM</b>  | Security Information and Event Management   |
| <b>TLS</b>   | Transport Layer Security                    |
| <b>WAF</b>   | Web Application Firewall                    |

Table of Contents

Executive Summary..... 2

Scenario, Scope and Assumptions ..... 2

    Abbreviations..... 3

Task 1: Understanding Cryptography Fundamentals in Context..... 5

Task 2: Analyzing Cryptographic Algorithms and Techniques Bloom’s Level: Analyze..... 6

Task 3: Applying PKI and Cryptographic Solutions Bloom’s Level : Apply ..... 9

Task 4: Evaluating Network Security Risks and Recommending Best Practices Bloom’s Level : Evaluate 12

    How TLS and IPsec Reduce the Risks..... 13

    Recommended Security Practices ..... 14

References..... 15

Annex A: AI Use Disclosure Statement..... 16

## Task 1: Understanding Cryptography Fundamentals in Context

**Q1. Explain how the CIA Triad (Confidentiality, Integrity, Availability) applies to the data and communications involved in your chosen topic. Use concrete examples specific to your topic.**

The CIA Triad is a practical way to identify what must be protected. For a social media account, confidentiality is not limited to passwords. Integrity includes the correctness of posts, profile settings and recovery information. Availability means that legitimate users should be able to access the platform and regain control of their accounts when needed.

| CIA property           | Meaning for SecureConnect                                                                                                                     | Concrete failure example                                                                                            | Main safeguards                                                                                                                                          |
|------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Confidentiality</b> | Only authorized users and services should see private messages, unpublished media, contact information, recovery codes and security settings. | An attacker who steals a session cookie reads private messages without knowing the password.                        | TLS 1.3; AES-GCM encryption at rest; least-privilege access; secure cookies; masked recovery data; HSM/KMS-protected keys.                               |
| <b>Integrity</b>       | Posts, profile details, login settings and audit records must not be changed without authorization or without detection.                      | A hijacker changes the registered email address, deletes recovery codes and publishes a fraudulent investment post. | Authenticated encryption; SHA-256 hashes; digital signatures for high-risk events; database access control; tamper-evident logging.                      |
| <b>Availability</b>    | The login, posting, messaging and account-recovery services should remain usable by legitimate users.                                         | A botnet floods the login API, or an attacker deliberately locks a victim out through repeated failed attempts.     | Rate limiting; DDoS protection; load balancing; redundant services; safe throttling rather than permanent lockout; tested backups and disaster recovery. |

The three properties are connected. For example, encrypting the account database supports confidentiality, but poor key management can make the data unavailable after a failure. Similarly, an aggressive lockout policy may reduce password guessing but can damage availability by allowing an attacker to lock many users out. The design must therefore balance the three objectives instead of treating them independently.

**Q2. Describe the relevant passive and active security attacks that threaten your chosen topic, and identify the security services and mechanisms (per the OSI Security Architecture) needed to counter them.**

ITU-T X.800 describes security services and related mechanisms for the OSI environment [1]. In this scenario, passive attacks attempt to learn information without visibly changing the system, while active attacks alter messages, impersonate users, replay data or interrupt service.

| Type           | Attack                                      | Social-media example                                                                                   | Required service                      | Mechanisms                                                                              |
|----------------|---------------------------------------------|--------------------------------------------------------------------------------------------------------|---------------------------------------|-----------------------------------------------------------------------------------------|
| <b>Passive</b> | Eavesdropping / release of message contents | Sniffing an open Wi-Fi network to capture login requests, private messages or session tokens.          | Data confidentiality; authentication. | TLS 1.3 encryption; certificate validation; secure cookies; optional traffic padding.   |
| <b>Passive</b> | Traffic analysis                            | Observing when a user logs in, message sizes or communication patterns even when content is encrypted. | Traffic-flow confidentiality.         | TLS record padding where justified; CDN/proxy aggregation; minimize metadata retention. |

| Type   | Attack                                   | Social-media example                                                                                     | Required service                            | Mechanisms                                                                                                    |
|--------|------------------------------------------|----------------------------------------------------------------------------------------------------------|---------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| Active | Masquerade / phishing                    | A fake login page collects credentials or an attacker uses stolen credentials to impersonate the victim. | Peer-entity authentication; access control. | Passkeys or MFA; server certificates; risk-based login checks; device alerts.                                 |
| Active | Replay                                   | A captured reset token, API request or authentication response is sent again.                            | Data-origin authentication; integrity.      | Nonces; timestamps; one-time tokens; short expiry; replay cache; TLS anti-replay controls.                    |
| Active | Message modification / man-in-the-middle | An attacker changes a profile-update request or redirects the client to an impostor service.             | Integrity; authentication.                  | TLS 1.3; AEAD; X.509 certificates; HSTS; signed high-risk events.                                             |
| Active | Session hijacking                        | A stolen session cookie is used to control the account after login.                                      | Access control; integrity; authentication.  | HttpOnly/Secure/SameSite cookies; token rotation; re-authentication for sensitive actions; anomaly detection. |
| Active | Denial of service                        | Flooding the login or recovery endpoint, exhausting resources or triggering mass lockouts.               | Availability.                               | WAF/CDN; rate limiting; queues; autoscaling; circuit breakers; recovery priority; monitoring.                 |

The most important point is that one mechanism may support several services. TLS provides confidentiality and integrity for data in transit, but account access still requires authentication and authorization. Likewise, encryption does not prevent a user from entering a password into a convincing phishing site; phishing-resistant authentication is needed for that threat.

## Task 2: Analyzing Cryptographic Algorithms and Techniques Bloom's Level: Analyze

**Q3. Identify and analyze at least two encryption algorithms (e.g., DES, AES, RSA) suitable for securing the data/communication in your chosen topic. Compare their key sizes, structures, strengths, limitations, and appropriate use cases.**

The proposed system uses symmetric and asymmetric cryptography together. AES is efficient enough to protect large amounts of data. RSA provides public-key operations for certificates and signatures, but it is too slow and size-limited for bulk social-media traffic. Modern TLS uses a hybrid construction: public-key techniques authenticate the endpoints and establish secrets, while symmetric authenticated encryption protects the session.

| Algorithm             | Type                                                      | Key / block size                               | Structure                                                                                               | Strengths                                                                                                                               | Limitations                                                                                                                      | Use in proposal                                                                                                                     |
|-----------------------|-----------------------------------------------------------|------------------------------------------------|---------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------|
| <b>AES-256-GCM</b>    | Symmetric block cipher with authenticated-encryption mode | 256-bit key; 128-bit block                     | Substitution-permutation network. GCM adds counter-mode encryption and a polynomial authentication tag. | Fast in hardware/software; provides confidentiality and integrity in one operation; suitable for databases, media keys and TLS records. | Nonce reuse under the same key is dangerous; keys must be generated, stored and rotated correctly.                               | Primary bulk-data and data-at-rest algorithm. NIST specifies AES-128, AES-192 and AES-256 [2].                                      |
| <b>RSA-3072</b>       | Asymmetric public-key algorithm                           | 3072-bit modulus; separate public/private keys | Modular exponentiation; security is based on the difficulty of factoring a large composite integer.     | Supports certificates, key transport in some protocols and digital signatures; public key can be widely distributed.                    | Much slower than AES; ciphertext/signature size is large; padding must be correct; vulnerable to future large quantum computers. | Use for selected X.509 certificate and RSA-PSS signature operations, not for bulk encryption. PKCS #1 is specified in RFC 8017 [3]. |
| <b>DES (rejected)</b> | Symmetric block cipher                                    | 56-bit effective key; 64-bit block             | 16-round Feistel network.                                                                               | Historically important and simple to study.                                                                                             | Key is far too small for modern systems; brute-force attacks are practical; small block size increases collision risks.          | Not suitable for SecureConnect. Included only to justify why a modern algorithm is required.                                        |

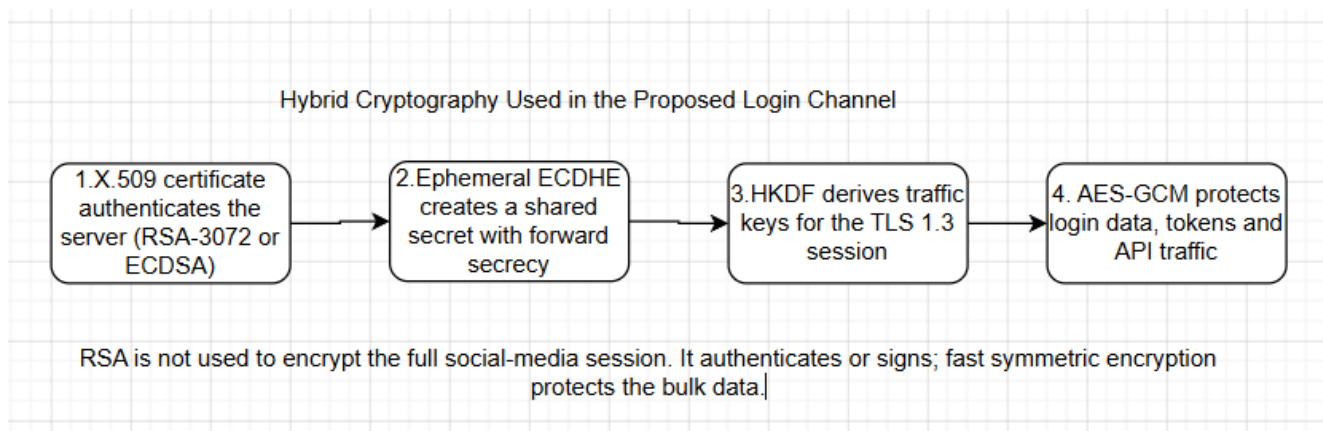


Figure 1. Hybrid use of asymmetric and symmetric cryptography in the proposed login channel. AES-256-GCM is preferred for high-volume encryption due to the same secret key being used for encryption and decryption, and its high efficiency for such a large workload. Meanwhile, RSA was recommended for the case where the encryption and decryption keys had to be different. NIST key-management guidance stresses the need for the proper protection of keying material, as cryptographic security must rely on it. This is why the control design called for the storage of long-term private keys in an HSM, the rotation of data-encryption keys, and the auditing of key-management practices to ensure that key-usage policies are followed. Even though the discussion centered around RSA, one of the fundamental algorithms covered in this course, in practice, the key-agreement component of the TLS 1.3 protocol suite should make use of ephemeral ECDHE to establish a shared secret. The latest standard for Transport Layer Security, specified in RFC 9846 (July 2026), defines authentication, confidentiality, and integrity as channel-security properties that should be provided by any TLS implementation.

**Q4. Analyze the underlying number-theoretic or structural basis of one algorithm you propose (e.g., modular exponentiation in RSA, substitution-permutation network in AES) and demonstrate it with a worked numerical example relevant to your topic.**

RSA uses modular arithmetic. Two large secret prime numbers are multiplied to create a modulus. Multiplication is easy, but recovering the original primes from a properly generated large modulus is computationally difficult with classical computers. The following small numbers are only for demonstration; real keys use a modulus thousands of bits long.

| Step                             | Calculation                                                                                                                           |
|----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| <b>1. Choose primes</b>          | $p = 61$ and $q = 53$ .                                                                                                               |
| <b>2. Compute modulus</b>        | $n = p \times q = 61 \times 53 = 3233$ .                                                                                              |
| <b>3. Compute Euler value</b>    | $\varphi(n) = (p - 1)(q - 1) = 60 \times 52 = 3120$ .                                                                                 |
| <b>4. Select public exponent</b> | Choose $e = 17$ , where $\gcd(17, 3120) = 1$ .                                                                                        |
| <b>5. Find private exponent</b>  | Find $d$ so that $e \times d \equiv 1 \pmod{3120}$ . The result is $d = 2753$ because $17 \times 2753 = 46801 = 15 \times 3120 + 1$ . |
| <b>6. Form keys</b>              | Public key = $(e, n) = (17, 3233)$ . Private key = $(d, n) = (2753, 3233)$ .                                                          |

**Relevant example**

Assume the small integer  $m = 65$  represents a demonstration login challenge or a tiny encoded session-key fragment. In a real system, RSA would use standardized padding such as OAEP for encryption or PSS for signatures; raw textbook RSA must not be deployed.

Encryption is calculated as  $c = m^e \bmod n = 65^{17} \bmod 3233$ .

| Repeated-squaring value | Result                                                               |
|-------------------------|----------------------------------------------------------------------|
| $65^2 \bmod 3233$       | 992                                                                  |
| $65^4 \bmod 3233$       | 1232                                                                 |
| $65^8 \bmod 3233$       | 1547                                                                 |
| $65^{16} \bmod 3233$    | 789                                                                  |
| $65^{17} \bmod 3233$    | $(65^{16} \times 65) \bmod 3233 = (789 \times 65) \bmod 3233 = 2790$ |

The ciphertext is therefore  $c = 2790$ . The holder of the private key decrypts it by calculating  $m = c^d \bmod n = 2790^{2753} \bmod 3233 = 65$ . The example demonstrates the public/private relationship: anyone may use the public key, but only the private-key holder should be able to perform the corresponding private operation. In practice, RSA security also depends on unpredictable prime generation, sufficient modulus size, side-channel protection and correct padding.



### Task 3: Applying PKI and Cryptographic Solutions Bloom's Level: Apply

**Q5. Apply the components of a Public Key Infrastructure (PKI) to design a secure authentication and communication solution for your chosen topic. Support your design with an architecture/flow diagram.**

PKI binds a public key to an identified subject through a digital certificate. For SecureConnect, PKI is used to authenticate public servers and internal services. It is not used as the only user-login method, because ordinary users should not be required to manage an X.509 certificate. User authentication is handled by passkeys or passwords plus MFA, while the platform infrastructure uses certificates to create trusted channels.

| PKI component                      | Role in SecureConnect                                                                                                                       |
|------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Offline Root CA</b>             | Top trust anchor. It signs only intermediate CA certificates and is kept offline except during controlled ceremonies.                       |
| <b>Intermediate / Issuing CA</b>   | Issues short-lived certificates to web servers, API gateways and internal services. Compromise can be contained without replacing the root. |
| <b>Registration Authority (RA)</b> | Verifies the requested service identity, domain and authorization before certificate issuance.                                              |
| <b>Certificate Repository</b>      | Publishes the certificate chain so clients and services can build and validate a trust path.                                                |
| <b>OCSP / CRL Service</b>          | Provides certificate-status information when a key or certificate must be revoked.                                                          |
| <b>HSM / KMS</b>                   | Generates and protects private keys and data-encryption keys, performs signing operations, controls rotation and records access.            |
| <b>Relying Parties</b>             | Browsers, mobile apps, API gateways and microservices that validate certificate subject, hostname, validity period, chain and status.       |
| <b>Audit / SIEM</b>                | Collects certificate issuance, key use, failed validation and authentication events for detection and investigation.                        |

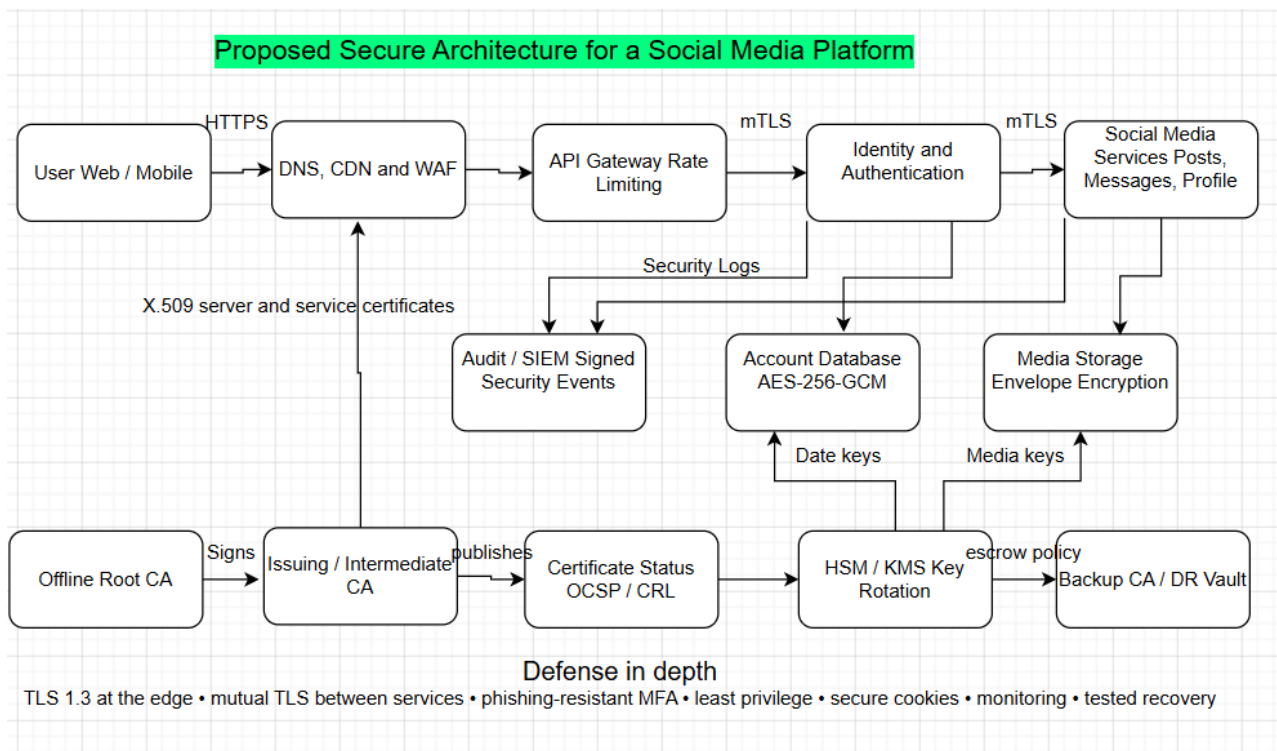


Figure 2. Proposed SecureConnect security architecture and PKI trust components. The primary authentication and communication lifecycle is as follows:

1. The user accesses the official website/app via HTTPS
2. Server responds with X.509 certificate chain. The client validates the certificate against the trusted CA chain, service hostname, expiration dates, key usage, revocation status, among other factors. RFC 5280 specifies the format of Internet X.509 certificates and CRLs.
3. TLS 1.3 establishes an ephemeral key exchange and subsequently derives symmetric keys for traffic encryption. Server authentication happens via private key signature over the handshake traffic.
4. User is prompted to authenticate with a passkey where available. Alternately, a password with an authenticator-app code can be submitted. NIST SP 800-63B-4 specifies current recommendations for authentication and authenticator management, including phishing resistance.
5. Identity service validates the authenticator with built-in rate limiting and adaptive security policies, issuing a limited-scope server-side session. Browser receives a Secure, Http Only and Same Site cookie instead of a JWT/session token containing personally identifiable information
6. High-risk operations like password/email change, MFA enrollment/reset, account recovery and other PII modifying actions always require fresh re-authentication or step-up authentication
7. Service-to-service communication uses mutually authenticated TLS with automatic certificate rotation. Private keys are stored in an HSM/KMS with strict access control policies.
8. SIEM receives security event logs. In case of compromise, server-side sessions are revoked, the user is alerted, compromised certificates/keys rotated if necessary and an incident investigation initiated.

The password storage mechanism is designed to be audited in case of a database breach. Rather than storing encrypted values, the service stores a salted Argon2id hash for every password with an individual

per-account salt. Both are needed to verify a password attempt. RFC 9106 specifies the memory-hard password hashing algorithm family and recommended parameters.

Such a design prevents the disclosure of individual passwords in case of database compromise and limits the impact surface. However, it is still possible to identify accounts with reused weak passwords and should be supplemented with monitoring of known-compromised values.

### **Q6. Apply digital signature and hashing techniques to ensure data integrity and non-repudiation within your proposed solution. Illustrate the signing and verification process with a diagram or step-by-step worked example.**

Hashing and signing are applied to high-risk security events rather than to every ordinary post. A useful example is an account-recovery approval. The signed record can show which security service approved the change, when it happened, which factors were verified and which administrator or automated policy authorized the action. This creates stronger evidence for later investigation.

#### **Worked hashing example**

Message: "User U1042 enabled passkey at 2026-07-31T14:20:00Z"

SHA-256 digest: 0460d913018c9b39414bea60480f3b40bff39d53c3af7e7102216f7673442619

A one-character change produces a different digest, so unauthorized modification is detectable.

| Stage                            | Implementation                                                                                                                                                                                |
|----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Create a canonical record</b> | Use a fixed order and encoding for user ID, action, timestamp, device ID, policy decision and request ID.                                                                                     |
| <b>Hash the record</b>           | Calculate SHA-256. NIST FIPS 180-4 specifies secure hash algorithms whose digests can be used to detect message changes.                                                                      |
| <b>Sign the digest</b>           | The security-event signing service asks the HSM to create an RSA-PSS signature with its private key. FIPS 186-5 includes RSA, ECDSA and EdDSA signature techniques.                           |
| <b>Store evidence</b>            | Store the original record, signature, certificate identifier, trusted timestamp and key version in an append-only audit store.                                                                |
| <b>Verify later</b>              | Recalculate the hash and verify the signature using the public key in the signer certificate. Also validate the certificate chain and signing time.                                           |
| <b>Interpret result</b>          | A valid result supports integrity and signer authentication. Non-repudiation is strongest when private-key access, time sources, identity proofing and audit procedures are also trustworthy. |

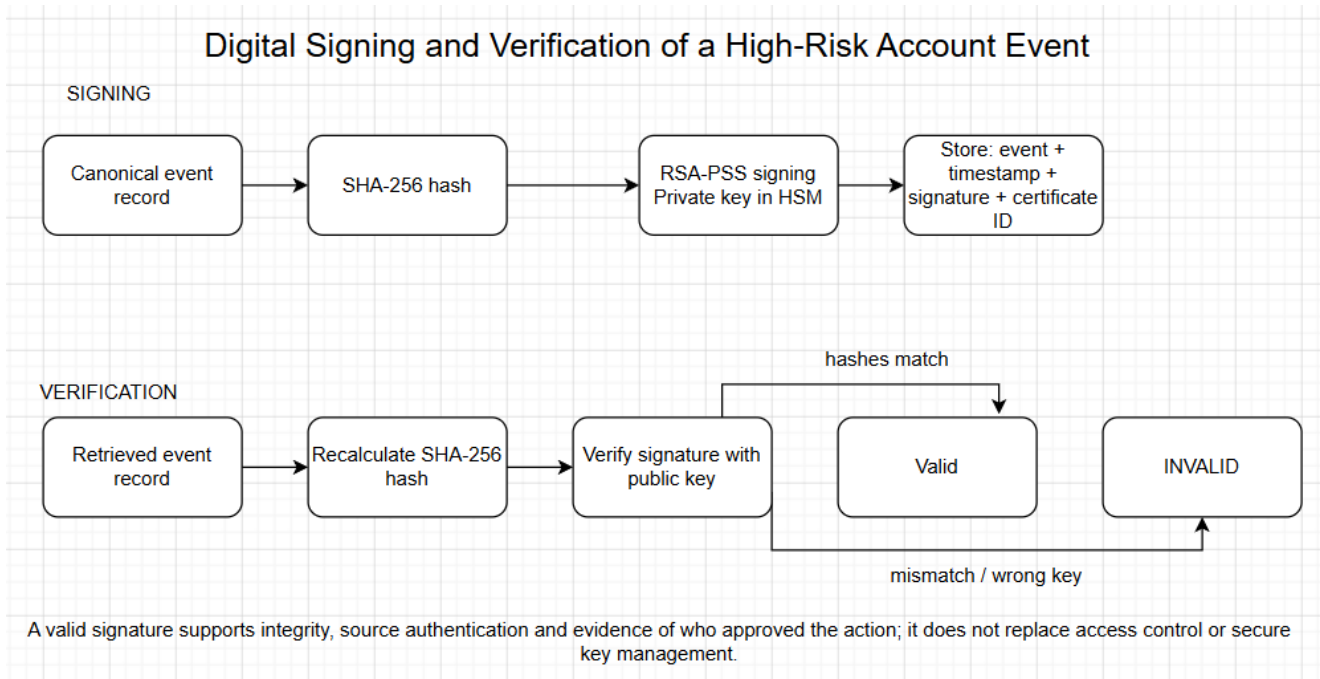


Figure 3. Signing and verification process for a high-risk account-security event.

A plain hash alone is not sufficient for non-repudiation because an attacker who can replace the message may also replace its hash. The digital signature links the digest to a protected private key. At the same time, the platform should avoid claiming absolute legal non-repudiation from cryptography alone. Shared administrator accounts, weak identity proofing or uncontrolled private-key access would weaken that claim.

## Task 4: Evaluating Network Security Risks and Recommending Best Practices

### Bloom's Level: Evaluate

**Q7. Evaluate the security, privacy, and trust risks present in your proposed solution (e.g., key management failure, certificate compromise, man-in-the-middle attacks, session hijacking, TCP/IP and OSI-layer vulnerabilities). Explain how IPSec and/or SSL/TLS could mitigate them.**

The proposed design is strong, but residual risk remains. The following matrix evaluates the most important risks. Likelihood and impact are qualitative because a real value would require platform telemetry, threat intelligence and business-impact data.

| Risk                                           | Likelihood | Impact | How it occurs                                                                             | Main mitigation                                                                                                                                   | Residual |
|------------------------------------------------|------------|--------|-------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| <b>Credential stuffing / password spraying</b> | High       | High   | Reused credentials from another breach are tested against many accounts.                  | Passkeys/MFA; breached-password screening; rate limits; bot detection; IP/device reputation; user alerts.                                         | Medium   |
| <b>Phishing and fake recovery support</b>      | High       | High   | The attacker tricks a user or help-desk agent into revealing or resetting authenticators. | Phishing-resistant passkeys; verified support channel; step-up checks; recovery delay; dual control for high-value accounts.                      | Medium   |
| <b>Session theft / hijacking</b>               | Medium     | High   | Malware, XSS or an exposed token allows control after successful login.                   | Secure/HttpOnly/SameSite cookies; CSP; token rotation; short inactivity timeout; device binding signals; re-authentication for sensitive actions. | Medium   |

| Risk                                               | Likelihood | Impact      | How it occurs                                                                               | Main mitigation                                                                                                                 | Residual   |
|----------------------------------------------------|------------|-------------|---------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|------------|
| <b>MITM or certificate compromise</b>              | Low-Medium | High        | Traffic is redirected or a stolen private key is used to impersonate the service.           | TLS 1.3; strict certificate validation; HSTS; short-lived certificates; HSM keys; OCSP/CRL; rapid revocation and rotation.      | Low-Medium |
| <b>Key-management failure</b>                      | Low-Medium | Critical    | Keys are leaked, lost, overused or restored incorrectly.                                    | HSM/KMS; least privilege; split duties; inventory; rotation; backup/restore tests; key-use logging; documented compromise plan. | Medium     |
| <b>Database breach / offline guessing</b>          | Medium     | High        | An attacker steals profile data and password hashes.                                        | AES-GCM; Argon2id with unique salts; data minimization; segmented database access; monitoring; encrypted backups.               | Medium     |
| <b>Insecure API, XSS or CSRF</b>                   | Medium     | High        | Application flaws bypass intended authentication or steal sessions.                         | Secure SDLC; code review; dependency scanning; WAF; CSP; CSRF defenses; authorization checks on every object.                   | Medium     |
| <b>Insider misuse</b>                              | Low-Medium | High        | A privileged employee reads private data or approves fraudulent recovery.                   | Role separation; just-in-time access; approval workflow; signed audit records; user notification; independent review.           | Medium     |
| <b>DDoS and mass lockout</b>                       | High       | Medium-High | Attackers exhaust edge resources or exploit lockout rules.                                  | CDN/WAF; autoscaling; adaptive throttling; proof-of-work/CAPTCHA only when needed; safe recovery queues; multi-region failover. | Medium     |
| <b>Privacy over-collection</b>                     | Medium     | High        | The platform stores excessive device, contact or behavioral data and increases breach harm. | Purpose limitation; short retention; consent; field-level access; pseudonymization; privacy review; deletion workflow.          | Medium     |
| <b>Third-party OAuth / supply-chain compromise</b> | Medium     | High        | A connected app or software dependency gains unexpected access.                             | Least-scope OAuth tokens; app review; token revocation; software bill of materials; dependency updates; vendor monitoring.      | Medium     |

## How TLS and IPsec Reduce the Risks

TLS 1.3 is the primary security control for user-platform and API traffic, providing server authentication, negotiable cryptography, traffic key generation and protection, and record integrity [5]. It thus helps mitigate passive interception, network-level credential disclosure, and man-in-the-middle attacks. Mutual TLS authentication can be used to secure communication with internal services. However, TLS does not carry protection for data at the destination, and cannot prevent users from making fraudulent requests on a legitimate session.

IPsec is a suitable alternative for securing communication below the application layer, such as for site-to-site, administrator VPN access, or data center interconnect. NIST SP 800-77 Rev. 1 recommends using IPsec VPNs for protecting communication between hosts or networks [15]. In the proposed design, IPsec tunnel mode would be used to secure replication and management traffic over insecure media, while TLS would provide transport-layer security for individual applications. This configuration would need to be evaluated carefully, since the combination of both security controls adds significant complexity to the system. Tunneling adds an additional layer of potential failure points, which can lead to outages or downtime due to configuration errors or IKE key rotation failures.

## Recommended Security Practices

- Prefer passkeys or other phishing-resistant authenticators for administrators, creators, verified accounts and users who opt in. Do not rely on SMS as the strongest available option by default, due to SIM-swap and interception possibilities.
- Use long-lived passwords as memorized secrets. Screen for known compromised values and resist to periodic password changes. In general, follow the guidance from the Open Web Application Security Project (OWASP), which states that passwords should be changed when there is suspicion of compromise, rather than periodically.
- Implement multifactor authentication (MFA) in a manner that requires stronger verification for enrollment, resets and factor replacement than what is needed for regular logins. MFA, according to the OWASP guidelines, requires more than one type of evidence for authentication.
- Treat a session token as an authentication factor. As such, do not allow reuse or persistence beyond the end of the session. The disclosure or capture of a session identifier is a possible cause of session hijacking, according to the OWASP guidelines. The rotation of session tokens upon login and privilege change, and their deletion following the password change or MFA reset helps mitigate the risk.
- Mitigate the risk of brute force, credential stuffing and password spraying attacks. The OWASP guidelines detail the differences between the attacks and recommend implementing MFA as a protection layer.
- Store the private keys in an HSM/KMS, use short-lived certificates and automate their rotation, renewals, revocations and inventory. Maintain an inventory of all keys and their owners, algorithms, versions and expiration dates.
- Encrypt sensitive data and limit its collection where possible. Separate production datasets from analytics databases. Destroy data that is not necessary for ongoing operations.
- Conduct regular secure code reviews, dependency scans, penetration tests, takedown drills, incident response exercises and cryptographic design reviews. Ensure that cryptographic controls are considered in the application and infrastructure security reviews.
- Develop an account compromise response plan. In case of an attack, the response should include termination of all sessions, freezing of potentially compromised privileged account changes to the infrastructure and applications, and contact with the user via an alternate channel to confirm the breach and provide recovery options. Additionally, evidence should be preserved for potential follow-on actions and legal proceedings, with evidence signing used where possible to establish provenance.
- Maintain a cryptographic migration strategy, which allows the replacement of algorithms and certificates without reengineering of the existing applications.

**Q8. Justify, in an overall concluding statement, why your proposed cryptographic/security solution represents a robust, trustworthy, and responsible application of network security principles.**

The offered solution is efficient as it relies on the defense-in-depth approach, covering all stages of the account lifecycle. It employs Transport Layer Security (TLS) 1.3 with mutual certificate authentication to establish a secure connection. It leverages efficient authenticated encryption schemes to protect sensitive data. It stores the user's password in memory-hard hashed form and favors phishing-resistant multi-factor authentication (MFA). The implementation also assumes the responsibility for the security of the session after authentication, focusing on recovery rather than relying on user behavior. The Public Key Infrastructure (PKI) and hardware security module (HSM) keys help create a simplified trust model that can be employed for both internal services and public-facing platforms. SHA-256 hashes and RSA-PSS signatures can make all high-risk audit records resistant to tampering and provide enough information to identify the origin of an unauthorized state change.

The proposed solution is trustworthy as it does not rely solely on encryption to secure user accounts. It acknowledges the presence of human and technology factors and utilizes industry-tested controls that mitigate particular threats. The controls explicitly address the threat landscape, and their absence is justified (Residual Risk section). The system adheres to the privacy principles of data minimization, limited retention of data, segregation of duties, and encryption. It ensures availability by leveraging rate-limiting features, redundancy, recovery tools, and well-documented disaster recovery plans.

Lastly, the solution is reliable and transparent as it uses established cryptographic standards. Its architecture is designed to protect the platforms while providing opportunities for independent auditing and continuous improvement over time. The Secure Connect proposal can be considered a practical application of the principle of confidentiality, integrity, authentication, non-repudiation, access control, and availability to secure social media accounts from being hacked.

## References

- [1] International Telecommunication Union, "ITU-T X.800: Security Architecture for Open Systems Interconnection for CCITT Applications," 1991. [Source](#)
- [2] National Institute of Standards and Technology, "FIPS 197: Advanced Encryption Standard (AES)," updated 2023. [Source](#)
- [3] K. Moriarty et al., "RFC 8017: PKCS #1: RSA Cryptography Specifications Version 2.2," RFC Editor, 2016. [Source](#)
- [4] E. Barker, "NIST SP 800-57 Part 1 Rev. 5: Recommendation for Key Management," NIST, 2020. [Source](#)
- [5] E. Rescorla, "RFC 9846: The Transport Layer Security (TLS) Protocol Version 1.3," RFC Editor, July 2026. [Source](#)
- [6] D. Cooper et al., "RFC 5280: Internet X.509 Public Key Infrastructure Certificate and CRL Profile," RFC Editor, 2008. [Source](#)
- [7] National Institute of Standards and Technology, "FIPS 180-4: Secure Hash Standard," 2015. [Source](#)
- [8] National Institute of Standards and Technology, "FIPS 186-5: Digital Signature Standard," 2023. [Source](#)
- [9] D. Temoshok et al., "NIST SP 800-63B-4: Digital Identity Guidelines - Authentication and Authenticator Management," NIST, 2025. [Source](#)
- [10] A. Biryukov et al., "RFC 9106: Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications," RFC Editor, 2021. [Source](#)
- [11] OWASP Foundation, "Authentication Cheat Sheet," OWASP Cheat Sheet Series, accessed 2026. [Source](#)
- [12] OWASP Foundation, "Multifactor Authentication Cheat Sheet," OWASP Cheat Sheet Series, accessed 2026. [Source](#)
- [13] OWASP Foundation, "Session Management Cheat Sheet," OWASP Cheat Sheet Series, accessed 2026. [Source](#)
- [14] OWASP Foundation, "Credential Stuffing Prevention Cheat Sheet," OWASP Cheat Sheet Series, accessed 2026. [Source](#)



## Annex A: AI Use Disclosure Statement

### 1. AI Tool Used

- **Tool Name:** ChatGPT
- **Version:** GPT-5.5 (OpenAI)
- **Access Date:** August 2026

### 2. Purpose of AI Usage

ChatGPT was utilized strictly in a supportive, advisory capacity to:

- Assist in structuring the layout and logical flow of the report.
- Refine grammar, improve sentence clarity, and enhance academic tone.
- Propose professional formatting styles.
- Clarify core cryptography and security concepts (including AES, RSA, TLS, PKI, SHA-256, and Digital Signatures).
- Aid in conceptualizing example tables and architectural diagrams based on original designs.
- Recommend industry-standard security frameworks and academic references for verification.

*Note: All analytical decisions, architectural choices, algorithm selection, diagrams, and the final content were rigorously reviewed, modified, and verified independently prior to submission.*

### 3. Summary of Prompts Used

During the preparation of this assignment, the following prompt categories and topics were engaged:

- Explaining the CIA Triad contextualized within the security topic "Protecting Social Media Accounts from Hacking."
- Comparing AES, RSA, and DES across performance, strengths, weaknesses, and primary use cases in a structured table.
- Demonstrating the cryptographic mechanics of RSA modular exponentiation via a worked numerical example.
- Designing a secure authentication and communication architecture incorporating PKI, TLS 1.3, Multi-Factor Authentication (MFA), and digital certificates.
- Illustrating digital signatures and SHA-256 hashing through a practical scenario.
- Assessing common cybersecurity vulnerabilities, including session hijacking, phishing, certificate compromise, and Man-in-the-Middle (MITM) attacks.
- Identifying best practice countermeasures aligned with prevailing security standards.
- Enhancing the overall academic tone, layout, and presentation quality of the draft.

### 4. Evaluation and Verification of AI Output

All text, code structures, and technical explanations generated with AI assistance underwent strict quality control. Specifically, the author:

- Cross-referenced cryptographic principles and security models against official course lecture materials, textbooks, and primary documentation.
- Corrected technical nuances and tailored explanations directly to the assignment's domain.



- Performed manual verification of the mathematical steps in the RSA numerical example.
- Validated reference lists and formatting guidelines against institutional submission requirements.
- Discarded generic or irrelevant recommendations that did not fit the scope of the project.

**5. Declaration of Responsibility** I hereby confirm that I utilized AI tools solely as an auxiliary aid in full compliance with the DIU AI Usage Policy (AMBER classification). I certify that I have thoroughly reviewed, edited, and validated every section of this document. I possess a complete understanding of all technical concepts and design decisions presented herein, and I accept full responsibility for the originality, technical accuracy, and final integrity of this submission. Furthermore, I acknowledge my obligation to explain and defend any part of this work during the viva-voce examination.

|                     |              |
|---------------------|--------------|
| <b>Student Name</b> | Fayek Ahanaf |
| <b>Student ID</b>   | 252-16-056   |
| <b>Signature</b>    |              |
| <b>Date</b>         |              |